

2FA simple bypass

Topic: Authentication | Difficulty: Apprentice

Description

After completing the first authentication factor the application establishes an authenticated session before verifying the second factor (OTP). By navigating directly to an authenticated page after the first factor an attacker with stolen credentials can bypass 2FA entirely without knowing the OTP.

Steps to Exploit

1. Log in with valid credentials (username and password) on /login.
2. When redirected to /login2 for OTP verification do NOT enter the code.
3. Manually navigate to /my-account in the browser's address bar.
4. Observe that full authenticated access is granted without providing the 2FA code.

Proof of Concept

Step 1 - Login:

```
POST /login (valid username + password submitted)
```

Step 2 - 2FA page:

```
Browser redirected to /login2 (OTP NOT entered)
```

Step 3 - Direct access:

```
GET /my-account --> 200 OK, full account access granted
```

Impact

- Complete bypass of the second authentication factor.
- Account compromise using only first-factor credentials.
- 2FA protection rendered entirely ineffective.
- Elevated risk from credential stuffing and phishing attacks.

Mitigation / Remediation

1. Do not issue fully authenticated sessions until all factors are successfully verified.
2. Enforce 2FA completion before granting access to any authenticated endpoint.
3. Implement server-side state machine tracking for multi-step authentication flows.
4. Redirect incomplete authentication sessions back to the 2FA page automatically.

CVSS Score

CVSS v3.1: 8.8 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

CVSS Justification

- Attack Vector: Network - requires only a browser and stolen credentials.

- Attack Complexity: Low - trivial URL navigation.
- Privileges Required: Low - requires valid first-factor credentials.
- User Interaction: None.
- Confidentiality / Integrity / Availability: High - full account access obtained.